Aktenvermerk

Kanzlei Dortschy & Thunert

Gegenstand: Nachweise zum Auftragsverarbeiter Amazon Web Services — AI-services-Opt-out-Richtlinie, Vertragslage, Zertifikate und Prüfberichte

Datum: 14. Oktober 2026

Zur Datenschutzakte. Betrifft die Datenschutz-Folgenabschätzung nach Art. 35 DSGVO zum Programm jusperfect sowie die Dokumentation der Dienstleisterauswahl nach § 43e Abs. 2 BRAO.

---

1. Anlass

Die Folgenabschätzung geht davon aus, dass bei der Verarbeitung durch die KI-Dienste von AWS keine Inhalte gespeichert und keine zur Verbesserung der Dienste verwendet werden. Eine Zweitprüfung hat am 5. Oktober 2026 festgestellt, dass dieser Schluss ohne eine wirksame AI-services-Opt-out-Richtlinie des Kontos nicht trägt. Bis zu deren Nachweis durfte keine Unterlage der Kanzlei eine Nicht-Speicherung behaupten.

Daneben war die Auswahl des Auftragsverarbeiters nach § 43e Abs. 2 BRAO zu dokumentieren.

Beides ist am heutigen Tage erledigt worden. Der Vorgang ist nachstehend festgehalten.

2. Was festgestellt wurde

2.1 Die Opt-out-Richtlinie

Betroffen ist das AWS-Konto **579138738703**, Region eu-central-1 (Frankfurt am Main).

1. Für das Konto wurde eine AWS-Organisation angelegt. Sie besteht aus diesem einen Konto; es ist zugleich das Verwaltungskonto. Eine Opt-out-Richtlinie ist nur innerhalb einer Organisation möglich.
2. Die Richtlinienart **„Abmelderichtlinien für KI-Services“** (AI services opt-out policies) wurde eingeschaltet.
3. Die Richtlinie **jusperfect-keine-ki-nutzung** wurde angelegt und an die Stammorganisation gehängt.
4. Am Konto wurde die **effektive** Richtlinie abgerufen. Sie lautet:

   ```
   { "services": { "default": { "opt_out_policy": "optOut" } } }
   ```

   Zeitpunkt der Feststellung: **14.10.2026, 17:11 Uhr MESZ.** AWS meldet keine Validierungsprobleme. Als Quelle ist „Verknüpft mit Root“ ausgewiesen.

> **Zum Unterschied zwischen erstellt und wirksam.** Eine angelegte, aber nicht angehängte Richtlinie bewirkt nichts und sieht in der Konsole fast genauso aus. Der Nachweis ist deshalb am Konto abgelesen worden und nicht an der Richtlinie. Damit ist zugleich geklärt, dass eine Richtlinie an der

> Stammorganisation auch das Verwaltungskonto erfasst — bei den Service-Kontrollrichtlinien ist das bekanntlich nicht so.

2.2 Die Vereinbarungen

In AWS Artifact wurden beide Reiter durchgesehen:

- **Kontovereinbarungen:** zehn Einträge, sämtlich inaktiv.
- **Organisationsvereinbarungen:** fünf Einträge, sämtlich inaktiv.

Es handelt sich durchweg um Zusatzvereinbarungen für besondere Lagen (Australien, Neuseeland, Japan, US-Gesundheitsdaten nach HIPAA, US-Wertpapieraufsicht nach SEC, kostenlose Beratungsleistungen). **Keine davon ist für die Kanzlei einschlägig; keine wurde angenommen.**

Ein gesonderter DSGVO-Zusatz steht dort nicht zur Annahme bereit. AWS hat ihn in die Kundenvereinbarung aufgenommen; er gilt ohne gesonderte Annahme.

2.3 Die Vertragslage

Es liegen vor und sind geprüft:

Unterlage	Fassung
AWS Data Processing Addendum (Auftragsverarbeitungsvertrag)	am 14.10.2026 abgerufen
AWS-Kundenvereinbarung, deutsche Fassung	Stand 01.06.2026
AWS-Datenschutzhinweis	Stand 18.05.2026
AWS Service Terms, Abschnitt 50.12 (Amazon Bedrock)	Stand 15.09.2026

Das Data Processing Addendum ist Abschnitt für Abschnitt gegen Art. 28 Abs. 3 DSGVO gelesen worden; **alle acht Punkte sind belegt.**

Sechs Feststellungen daraus:

1. **Die Nutzungsschranke steht in der Kundenvereinbarung, nicht im Auftragsverarbeitungsvertrag.** Deren Ziffer 1.4 ist die tragende Stelle und reicht weiter, weil sie für „Ihre Inhalte“ gilt und nicht nur für personenbezogene Daten: AWS greift auf Inhalte nicht zu und nutzt sie nicht, außer soweit zur Wartung oder Erbringung der Services nötig oder gesetzlich gefordert. Ergänzend Ziffer 6.1.
2. **Der Datenschutzhinweis gilt ausdrücklich nicht für Akteninhalt**, sondern nur für Account-Informationen. Er nennt als Zweck unter anderem die Verbesserung der AWS-Angebote; dieser Zweck betrifft den Akteninhalt nicht.
3. **Vertragspartei ist für Kunden mit Sitz in der EU die Amazon Web Services EMEA SARL, Luxemburg.** Ihr gegenüber ist die Haftung für grobe Fahrlässigkeit und Vorsatz nicht beschränkt.
4. **Die Service Terms, Abschnitt 50.12, enthalten für Amazon Bedrock keine Erlaubnis, Inhalte zum Training oder zur Verbesserung der Dienste zu verwenden.** Das ist von Bedeutung, weil die Service Terms sowohl dem

Auftragsverarbeitungsvertrag (Abschnitt 16) als auch der Kundenvereinbarung (Ziffer 11.2) vorgehen. Die Schranke aus Ziffer 1.4 bleibt damit unangetastet. Dass dieses Schweigen Absicht ist, zeigt der unmittelbar folgende Abschnitt 50.13 zu Amazon Q: Dort nimmt AWS sich das Gegenteil ausdrücklich heraus, einschließlich des Trainierens von Machine-Learning-Modellen, und verweist für den Widerspruch auf die Opt-out-Richtlinie.

5. **Abschnitt 50.12.2 regelt jedoch eine Speicherung.** Für bestimmte, auf einer eigenen Seite von AWS genannte Modelle speichert Amazon Bedrock **Ein- und Ausgaben bis zu 30 Tage** zum alleinigen Zweck der Erkennung von Verstößen gegen die Nutzungsbedingungen und **überprüft sie im Verdachtsfall**. Der Nachbarabschnitt zu Kiro (50.14.2) spricht dabei von „möglicher menschlicher Überprüfung“. Siehe Abschnitt 4 dieses Vermerks.
6. **Nach Abschnitt 50.12.1 hängt die Rechtslage am gewählten Modell.** Ein Modell eines Drittanbieters aus dem AWS Marketplace brächte dessen eigene Bedingungen mit. Die Modellwahl in jusperfect ist deshalb keine rein technische Einstellung.

Die Kundenvereinbarung, der Datenschutzhinweis und die Service Terms liegen in deutscher Übersetzung vor und tragen den Hinweis, dass bei Abweichungen die **englische Fassung maßgeblich** ist.

2.4 Die Nachweise der Prüfer

Aus AWS Artifact wurden am 14.10.2026 abgerufen:

Nachweis	Gegenstand
ISO 27001:2022 Certification	Informationssicherheit
ISO 27017:2015 Certification	Sicherheit in der Cloud
ISO 27018:2019 Certification	Schutz personenbezogener Daten in der Cloud
ISO/IEC 27701:2019 Certification	Datenschutz-Managementsystem
System and Organization Controls (SOC) 2 Report, Typ 2	Berichtszeitraum 1. April 2025 bis 31. März 2026; geprüfte Kriterien: Security, Availability, Confidentiality, Privacy
System and Organization Controls (SOC) 3 Report	dasselbe Prüfurteil in weitergabefähiger Fassung
SOC Continued Operations Letter	Fortgeltung der geprüften Kontrollen über den Berichtszeitraum hinaus

2.5 Die Missbrauchserkennung bei Amazon Bedrock

Gelesen am 14.10.2026: der Abschnitt „Abuse detection“ des Amazon Bedrock User Guide — die Seite, auf die Abschnitt 50.12.2 der Service Terms verweist — sowie Abschnitt 1.24 der Service Terms. Der User Guide ist Dokumentation und kein Vertrag; AWS kann ihn ohne Ankündigung ändern.

Abschnitt 1.24 betrifft die Kanzlei nicht. Er regelt andere AWS-Dienste mit eingebauter, von Bedrock betriebener KI-Funktion (genannt werden unter anderem CloudWatch, CodeCatalyst, Connect, Q, SageMaker, Kiro und

GuardDuty). jusperfect ruft die Bedrock-Schnittstelle unmittelbar auf und nutzt keinen dieser Dienste.

Die Seite nennt die betroffenen Modelle namentlich:

Modell	Was aufbewahrt wird
OpenAI-Modelle, bis auf vier genannte	vom Klassifikator aufgefallener Verkehr, bis zu 30 Tage
Anthropic Claude Fable 5 und Claude Fable 5.1	der gesamte Verkehr, bis zu 30 Tage; aufgefallener Verkehr zusätzlich mit möglicher menschlicher Überprüfung durch AWS
alle übrigen	nichts; es gilt das Zero-Operator-Access-Modell

Das von jusperfect genutzte Modell anthropic.claude-opus-4-6-v1 steht nicht auf dieser Liste. Für die Verarbeitung der Kanzlei gilt damit nach dem Stand vom 14.10.2026: **keine Aufbewahrung und keine Überprüfung.** Die Kanzlei hat am 14.10.2026 bestätigt, dass dieses Modell im Betrieb eingestellt ist.

Drei Angaben derselben Seite gehören dazu:

1. Würde ein gelistetes Modell genutzt, lägen die aufbewahrten Daten bei regionsübergreifender Inferenz in der jeweiligen Verarbeitungsregion.
2. Die Erkennung von Darstellungen des Kindesmissbrauchs arbeitet auf Bild-Ein- und -Ausgaben. jusperfect sendet an Bedrock ausschließlich Text.
3. Aufbewahrtes wird nicht an die Modellanbieter weitergegeben.

> **Eine Betriebspflicht, die daraus folgt:** Erkennt AWS einen möglichen Verstoß, richtet es Rückfragen an die E-Mail-Adresse des AWS-Kontos und kann den Zugang sperren, wenn keine Antwort erfolgt. Diese Adresse ist zu pflegen und zu lesen.

3. Was daraus folgt

1. **Für Amazon Textract** — die Texterkennung gescannter Seiten — ist damit belegt, dass Inhalte weder gespeichert noch zur Entwicklung und Verbesserung der AWS-KI-Dienste verwendet werden. Der Vorbehalt vom 5. Oktober 2026 ist gegenstandslos; die Unterlagen der Kanzlei sind entsprechend berichtigt worden.
2. **Für Amazon Bedrock** — die Verarbeitung im Sprachmodell — gilt das **nicht aus dieser Richtlinie.** Die Abmelderichtlinie erfasst Bedrock nicht. Dort trägt die vertragliche Schranke aus Ziffer 1.4 der Kundenvereinbarung, die durch die Service Terms bestätigt und nicht eingeschränkt wird. Die Aufbewahrung nach Abschnitt 50.12.2 greift für das **genutzte Modell nicht** (Abschnitt 2.5); für die dort gelisteten Modelle gälte sie.

3. **Die Auswahl des Auftragsverarbeiters** ist mit den unter 2.4 genannten Nachweisen belegbar. Die Bewertung, ob sie die Anforderungen des § 43e Abs. 2 BRAO tragen, bleibt der Kanzlei vorbehalten.
4. **Nicht belegt und auch nicht behauptet** ist, dass AWS die Inhalte nicht lesen könne. Bedrock und Textract verarbeiten im Klartext; das ist technisch nicht anders möglich. Es handelt sich um Auftragsverarbeitung nach Art. 28 DSGVO und nicht um einen Vorgang, dem durch Verschlüsselung der Personenbezug genommen wäre.

4. Was offen bleibt

Drei Punkte zur Missbrauchserkennung, nachdem die beiden Sachfragen geklärt sind (Abschnitt 2.5):

1. **Die Liste gehört in die jährliche Durchsicht.** Sie ist Dokumentation und kein Vertrag; AWS kann ein Modell aufnehmen, auch das genutzte. Dann änderte sich die Bewertung.
2. **Zwei Hausregeln in die Einweisung:** Für Mandatsakten wird kein Modell verwendet, das auf der Missbrauchserkennungsseite steht, und vor jedem Modellwechsel wird sie angesehen. Die E-Mail-Adresse des AWS-Kontos wird gelesen.
3. **Die Hinweise nach Art. 13 DSGVO:** Nach heutigem Stand ist über eine Aufbewahrung bei Bedrock nichts zu sagen. Ändert sich die Liste, ändert sich das.

Ferner zur Vervollständigung der Ablage: die englischen Fassungen der übersetzten Stücke, die Standardvertragsklauseln und die Liste der Unterauftragsverarbeiter.

5. Umgang mit den Anlagen

Der SOC-2-Bericht ist vertrauliche Information von AWS. Beim Abruf wurde die zugehörige Vertraulichkeitsvereinbarung angenommen. Daraus folgt:

1. **Keine Auszüge.** Aus dem Bericht darf ohne ausdrückliche schriftliche Zustimmung von AWS nicht zitiert werden — auch nicht in der Folgenabschätzung oder in einem Schriftsatz.
2. **Weitergabe an eine Aufsichtsbehörde ist zulässig**, jedoch nur vollständig und unter ausdrücklichem Antrag auf vertrauliche Behandlung.
3. **An Mandanten ist stattdessen der SOC-3-Bericht zu verwenden.**
4. **Über jede Weitergabe ist Buch zu führen** (Datum, Empfänger, Anlass); AWS kann Einsicht in diese Aufzeichnungen verlangen.

Die Anlagen verbleiben in der Datenschutzakte und werden **nicht** in den Programmordner von jusperfect übernommen, da dieser weitergegeben wird.

6. Wiedervorlage

Die Prüfberichte decken einen Zeitraum ab und veralten. Sie sind im Rahmen der **jährlichen Durchsicht der Datenschutz-Folgenabschätzung** neu abzurufen. Eine gesonderte Frist wird nicht notiert.

7. Anlagen

1. Bildschirmausdruck: effektive AI-Richtlinie für Konto 579138738703, 14.10.2026, 17:11 Uhr MESZ
2. Bildschirmausdruck: angewendete Richtlinien am Konto, Quelle „Verknüpft mit Root“
3. Bildschirmausdruck: Konto- und Organisationsvereinbarungen in AWS Artifact
4. AWS Data Processing Addendum
5. AWS-Kundenvereinbarung, Fassung 01.06.2026
6. AWS-Datenschutzhinweis, Fassung 18.05.2026
7. ISO 27001:2022 Certification
8. ISO 27017:2015 Certification
9. ISO 27018:2019 Certification
10. ISO/IEC 27701:2019 Certification
11. SOC 2 Report, Typ 2, Berichtszeitraum 01.04.2025 – 31.03.2026
12. SOC 3 Report
13. SOC Continued Operations Letter
14. Vertraulichkeitsbedingungen für den Abruf der SOC-Berichte — Bildschirmausdruck des Dialogs und vollständiger Ausdruck über die Schaltfläche „Bedingungen ausdrucken“
15. Bildschirmausdruck: AWS Service Terms, Stand 15.09.2026, Abschnitt 50.12 (Amazon Bedrock) nebst Abschnitt 50.13 (Amazon Q) zum Vergleich
16. Bildschirmausdruck: AWS Service Terms, Abschnitt 1.24
17. Seite „Amazon Bedrock abuse detection“ aus dem Amazon Bedrock User Guide, abgerufen am 14.10.2026 — Abschrift des Wortlauts und Ausdruck der Seite

---

Ort, Datum .....

Unterschrift .....